AI-Assisted Software Development Internship

Weeks 3-4 | Days 13-20 | Full Task Report

Token diet, tests that matter, security and privacy, AI-COO, safe agents, capstone, demo and retrospective

Prepared by: Mirza Yasir Abdullah Baig

Role: AI Engineer

GitHub user: mirzayasirabdullahbaig07

Repository: https://github.com/mirzayasirabdullahbaig07/AI-Internship

Date: 14 October 2026

1. Summary

Days 13 to 20 were completed as separate folders in the same repository as Days 1-12 (one folder per day: code, tests, demo, screenshots, README), merged with a clean history: 81 commits on `main` and 36 branches in total. This report covers Days 13-20; the earlier reports are in the `reports/` folder.

Day	Deliverable	Tests	Key evidence
13	Token diet: 1,177-word prompt to a 123-word brief	8	13/13 criteria kept, -89.5% words, negative control
14	One component test, one browser journey, mutation check	6	Weak tests catch 0/6 bugs, component 4/6, browser 5/6, together 6/6
15	Security and privacy: OWASP Top 10:2025 review, secure rewrite	22	Insecure API fails 20/22; demo 5/5 attacks exploited vs 0/5
16	AI-COO operating inputs and validator	23	14 checks; real inputs INVALID until a human reviewer is named
17	AI-COO lifecycle and the 'Add dark mode' split	49	8 task cards in 5 waves; human gates enforced in code
18	Working safely with agents: scanner, audit, handoff	44	0 secret findings in 204 files; 4 GitHub settings reported MANUAL
19	Capstone: responsive Leave Request form	44 + 1 flow	axe 0 violations in 7 states; 12/12 planted bugs caught; 2 review bugs fixed
20	Demo, review, retrospective, dashboard	5	15 things that went wrong, logged honestly

Final verification: `npm run verify` on commit `851ffc9` exits 0 with Prettier clean, TypeScript clean, **22 suites and 260 tests passed** (whole repository, Days 3-20), 0 failing.

2. Honest status (read first)

• **Nothing is pushed to GitHub and no pull request is open.** That needs your account. Hosted CI has never run (`.github/workflows/verify.yml` is untested).

• **No human reviewer is named.** `day-16-ai-coo/inputs/coo_inputs.json` has `humanReviewer: null` on purpose; the validator reports it INVALID rather than inventing a person. 'Ayesha Khan' in demos is a fake lab persona.

• **GitHub branch protection, secret scanning, token scopes and the audit log are unverified**; the Day 18 audit reports them as MANUAL, never as passed.

• **The reviews on Days 12 and 20 were by the same AI that wrote the code** (practice reviews, not peer reviews). Findings were proven by tests and real-browser probes.

• **The work was produced by Claude from your instructions.** The handbook passes an intern only if they can explain their own code without reading an AI answer; `day-20-demo-retrospective/STUDY_GUIDE.md` is for that.

• No manual screen-reader test was done; automated accessibility checks cover only part of WCAG. Browser checks ran in Chromium only.

• Token numbers are a characters/4 estimate, not a real tokenizer. Sample logs, prompts and instructor material that were not available were written by me and are labelled as such.

3. Day 13 - Keeping AI Token Use Low

Lab: cut an overly verbose ~1,000-word prompt (company history, emotional pleas) to a sterile 150-word task brief without losing the acceptance criteria. The instructor's prompt was not available, so I wrote a 1,177-word sample with the same kinds of noise. The brief is for the Leave Request capstone, so it also drove Day 19.

Measured result

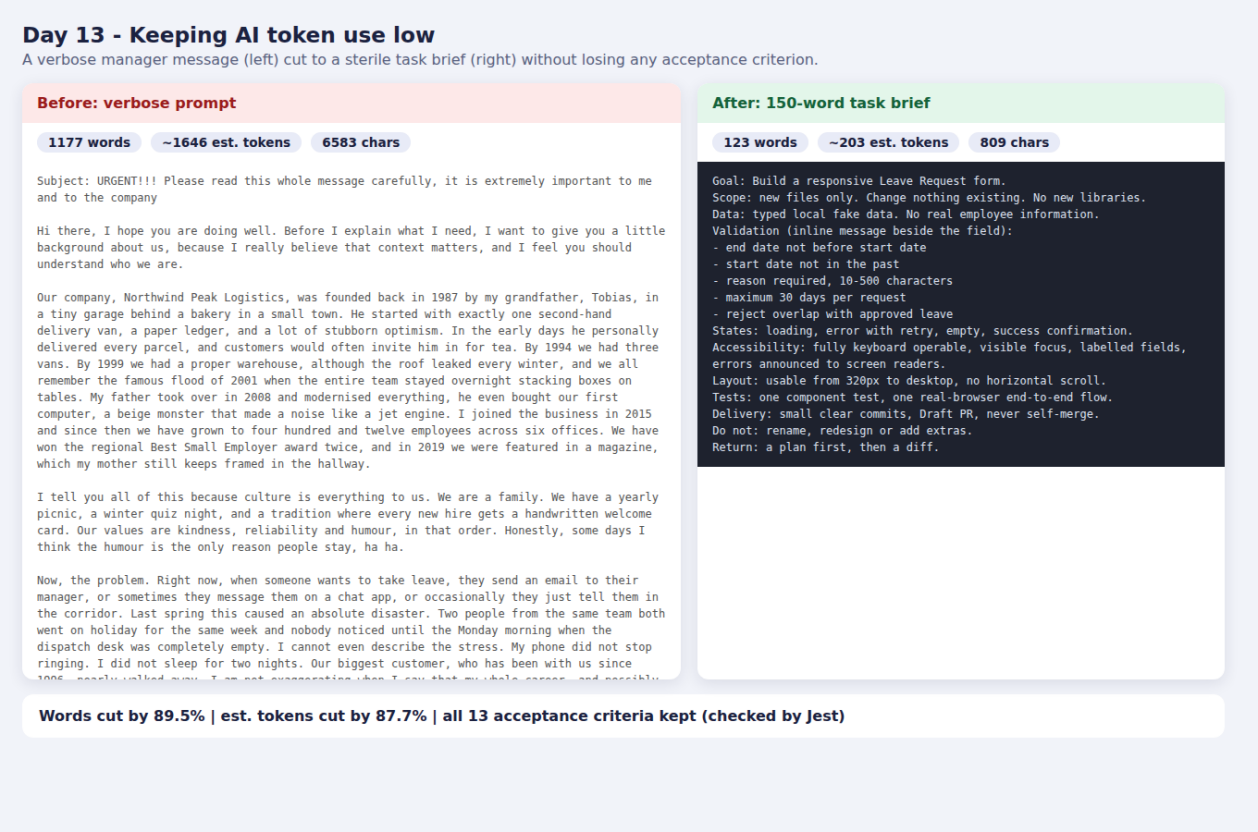
```
Verbose prompt : 1177 words, 6583 chars, ~1646 est. tokens, 12/12 noise markers
Task brief     : 123 words, 809 chars, ~203 est. tokens, 0/12 noise markers
Reduction      : words -89.5%, est. tokens -87.7%
Criteria kept  : 13/13
(Token numbers are a chars/4 ESTIMATE, not a real tokenizer.)
```

The 123-word brief (Standard Task Prompt Structure)

```
Goal: Build a responsive Leave Request form.
Scope: new files only. Change nothing existing. No new libraries.
Data: typed local fake data. No real employee information.
Validation (inline message beside the field):
- end date not before start date
- start date not in the past
- reason required, 10-500 characters
- maximum 30 days per request
- reject overlap with approved leave
States: loading, error with retry, empty, success confirmation.
Accessibility: fully keyboard operable, visible focus, labelled fields, errors announced to screen readers.
Layout: usable from 320px to desktop, no horizontal scroll.
Tests: one component test, one real-browser end-to-end flow.
Delivery: small clear commits, Draft PR, never self-merge.
Do not: rename, redesign or add extras.
Return: a plan first, then a diff.
```

Strategies applied

Strategy	Where / measured
Short brief	1,177 -> 123 words; ~1,646 -> ~203 estimated tokens
Targeted diffs	Day 12 reviewer saw a 194-line diff, not the repository
Plan first	outputs/PLAN_FIRST.md: the plan is approved before any code
Markdown caching	whole-repo source (54 files): ~22920 est. tokens | cache: ~487 est. tokens | saved: 97.9%
Tiered models, free-tier fallacy	outputs/MODEL_TIERS.md (guidance, not measured)



Demo screenshot: before (left) and after (right). Counters are computed in the browser and match the Node counts (browser counts: verbose=1177, brief=123 | node counts: verbose=1177, brief=123 -> MATCH)

How 'no criterion lost' was checked

Thirteen acceptance criteria are each defined by regular-expression patterns for both texts. The tests prove every criterion exists in the verbose original (so the checker is not vacuous), survives in the brief, that 0 of 12 noise markers remain, and that a **negative control** (deleting the 30-day line) is reported as lost criterion C6. While reviewing the regex I noticed the noise word 'tea' would also match 'team' and fixed it with word boundaries before it caused a false result. 8 tests pass.

Honest limits: regexes can miss paraphrases, so a human still reads the brief. Reason length 10-500 is my concrete choice for the original's 'sensible minimum and maximum'.

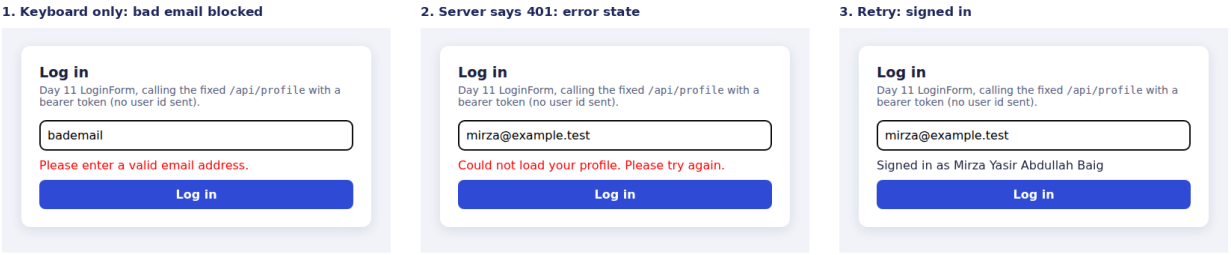
4. Day 14 - Tests That Matter

Lab: instruct an AI to create **one component test** and **one browser journey** for a form, then explain what each proves that the other misses. Subject: the Day 11/12 LoginForm. To measure rather than assert, I planted six realistic bugs in a copy of the form and recorded which test layer noticed each.

Measured result (real run)

ID	Planted bug	Weak tests	Component	Browser
M0	baseline (original code, no bug)	pass	pass	pass
M1	validation removed (bad email is submitted)	missed	CAUGHT	CAUGHT
M2	error text no longer red	missed	CAUGHT	CAUGHT
M3	HTTP 401 treated as success (res.ok check removed)	missed	missed	CAUGHT
M4	client sends a user id again (?userId=2)	missed	CAUGHT	missed
M5	apiBase ignored (wrong URL wiring)	missed	missed	CAUGHT
M6	Authorization header not sent	missed	CAUGHT	CAUGHT

```
Bugs caught (of 6): weak tests 0, component test 4, browser journey 5, component+browser together 6
Baseline (original code) passes every layer: yes
```



Demo screenshots of the keyboard-only browser journey: bad email blocked, server 401 shows an error state, retry signs in

Check: what each test proves that the other misses

• **Component test proves what the browser misses:** the exact contract. It catches M4 (the client sending `?userId=2` again) because the fixed server ignores that parameter, so the user-visible result still looks right.

• **Browser journey proves what the component test misses:** that the pieces work together. It catches M3 (HTTP 401 treated as success) and M5 (wrong URL wiring), because the component test mocks `fetch` and a mocked 'ok' hides both.

• **Weak AI-style tests prove nothing:** `toBeDefined()`, 'renders without crashing' and `true === true` caught 0 of 6 bugs.

A wrong result I caught in my own harness

My first run said the browser journey 'caught' M4. That was for the wrong reason: Playwright's glob `**/fixed/api/profile` does not match a URL with a query string, so my fake-401 interception never fired and the journey failed at the wrong step. I switched to a regex, re-ran, and M4 correctly became 'missed' by the browser. The table above is from the corrected run. Six mutants are a small hand-picked sample, not a full mutation score.

5. Day 15 - Security and Privacy

Lab: review an intentionally insecure Node.js endpoint and list the missing OWASP checks. I built a notes API (login, list, create, delete) with deliberate flaws, reviewed it against **OWASP Top 10:2025** (edition confirmed on owasp.org), wrote a secure version, and ran one test file against both. All users, passwords and notes are fake.

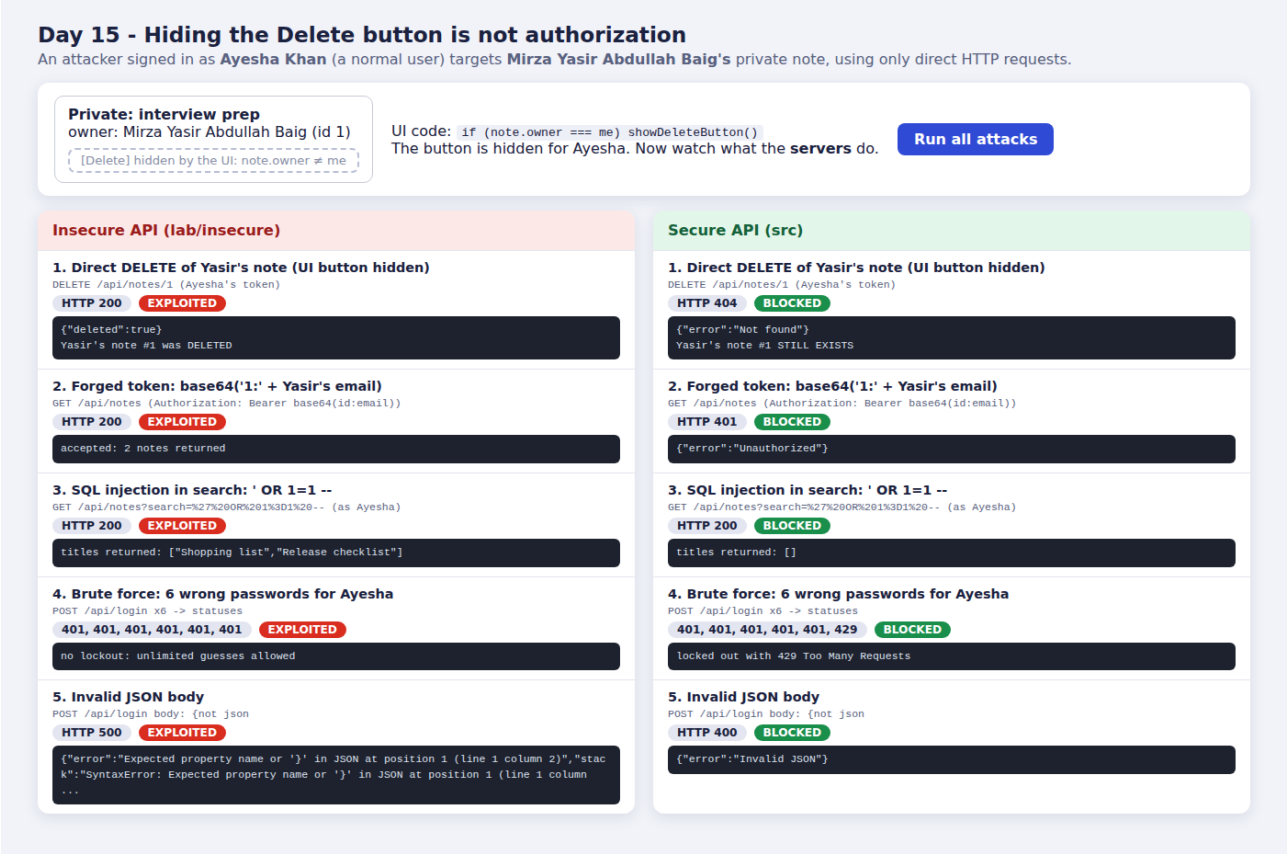
Missing OWASP checks (each proven by a test that fails on the insecure code)

OWASP 2025	Missing check in the insecure endpoint
A01 Broken Access Control	No ownership check on DELETE; client-supplied owner_id trusted; list returns everyone's notes
A02 Security Misconfiguration	CORS *, no nosniff / no-store, stack traces returned
A03 Supply Chain Failures	Checked with a real npm audit: 0 runtime vulnerabilities; 19 moderate advisories in dev-only tooling, suggested fix is a breaking downgrade, so NOT applied (accepted dev-only risk)
A04 Cryptographic Failures	Unsalted MD5 passwords; forgeable base64(id:email) token
A05 Injection	SQL concatenation in login, user lookup and search (UNION login bypass proven)
A06 Insecure Design	No length, size or per-user limits
A07 Authentication Failures	User enumeration, no rate limit, tokens never expire
A08 Data Integrity Failures	NOT demonstrated or tested by this endpoint (stated honestly)
A09 Logging and Alerting	Logs passwords and Authorization headers; no security events
A10 Exceptional Conditions	Invalid JSON gives 500 plus stack trace; DB errors echoed

Real results

```
$ npm run test:insecure   (TARGET=insecure - EXPECTED to fail; failures prove the findings)
      [FAIL] a user cannot delete someone else's note (and the note survives) (42 ms)
      [PASS] an owner can delete their own note (16 ms)
      [PASS] an admin can delete any note (21 ms)
      [FAIL] owner_id in a POST body is ignored: the caller always owns what they create (20 ms)
      [FAIL] listing notes returns only the caller's notes (29 ms)
      [FAIL] secure response headers are set and CORS is not wide open (19 ms)
      [FAIL] passwords are stored with a salted slow hash, not MD5 (1 ms)
      [FAIL] session tokens are random (two logins differ) and long (13 ms)
      [FAIL] SQL injection in the search term does not expose other users' notes (13 ms)
      [FAIL] a malformed search term does not produce a database error (7 ms)
      [FAIL] SQL injection in login (UNION SELECT) cannot log an attacker in as the admin (6 ms)
      [FAIL] title and body have length limits (5 ms)
      [FAIL] a user cannot create unlimited notes (94 ms)
      [FAIL] an oversized request body is refused (413) (6 ms)
      [FAIL] unknown user and wrong password are indistinguishable (no user enumeration) (6 ms)
      [FAIL] login is rate limited: 5 failures lock the account (429), even for the right password (10 ms)
      [FAIL] a forged token (base64 of id:email) is rejected (4 ms)
      [FAIL] sessions expire (7 ms)
      [FAIL] logs never contain passwords or tokens (5 ms)
      [FAIL] failed logins and denied actions produce security events (7 ms)
      [FAIL] responses expose no more personal data than needed (no emails, no hashes) (11 ms)
      [FAIL] invalid JSON gives a clean 400 with no stack trace (3 ms)
 Tests:       20 failed, 2 passed, 22 total
```

Secure code: **22 of 22** tests pass. Insecure code: **20 fail, 2 pass** (owners and admins may delete: legitimate behaviour).



Demo screenshot: five direct attacks against the insecure API (left, all EXPLOITED) and the secure API (right, all BLOCKED)

Check: why hiding a 'Delete' button in the frontend HTML is not authorization

HTML, CSS and JavaScript run on the user's machine, so they are suggestions the user can change. An attacker does not need the button: it is only a way to send an HTTP request, and they can send `DELETE /api/notes/1` directly with curl, fetch or Postman. The demo shows exactly this: the UI hides the button for Ayesha, yet the insecure API returns `200 {"deleted":true}` and Yasir's note is gone; the secure API returns `404` and the note survives. Authorization must be enforced on the server, on every request, using the verified identity and the resource's owner.

A bug the tests found in my own secure code

The first secure run failed the oversized-body test: I called `req.destroy()` before sending the 413, so clients saw a dropped connection. I fixed the code (drain the upload, answer 413 with `Connection: close`) and did not touch the assertion.

6. Day 16 - What an AI-COO Is For

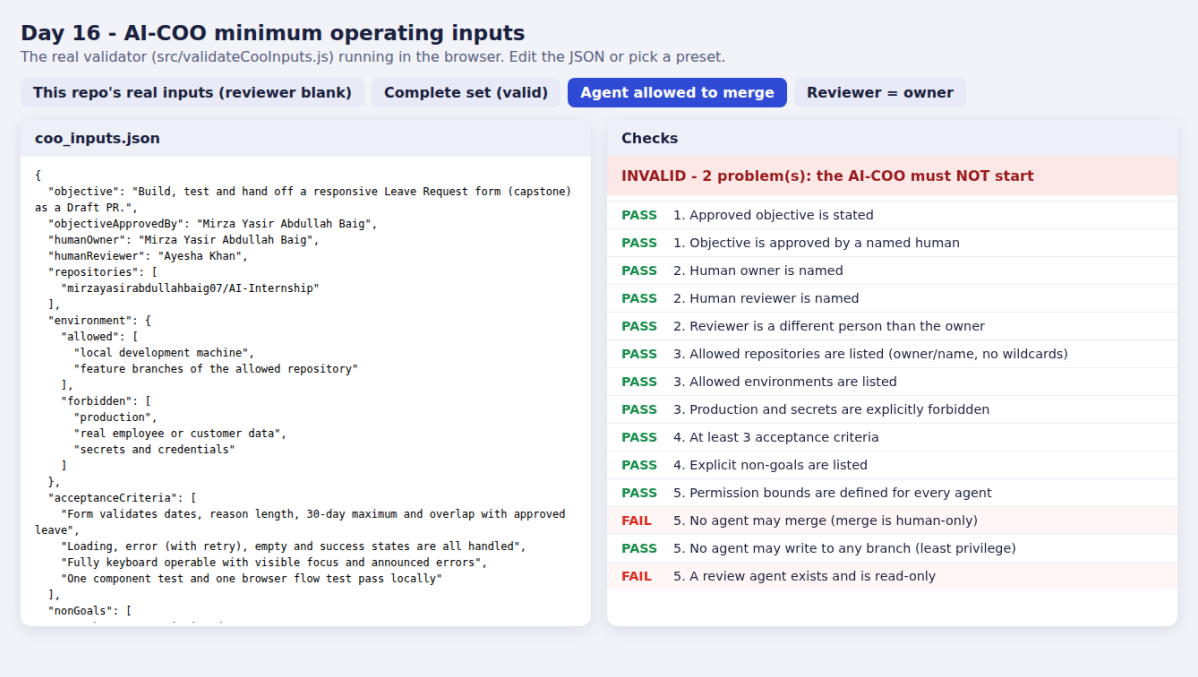
An AI-COO coordinates: it turns an approved objective into scoped tasks, assigns them, tracks evidence and queues reviews. It needs five minimum inputs: an approved objective; a named human owner *and* reviewer; allowed repositories and environment boundaries; acceptance criteria and non-goals; permission bounds (Read/Write/Merge). I wrote the AI-COO operating brief and a **14-check validator** that enforces them, including that the reviewer is a different person than the owner, no agent may merge, no agent may write to any branch, and a read-only review agent must exist.

Real run on this repository's inputs

```
$ node day-16-ai-coo/src/cli.js day-16-ai-coo/inputs/coo_inputs.json
[PASS] 1. Approved objective is stated
[PASS] 1. Objective is approved by a named human
[PASS] 2. Human owner is named
[FAIL] 2. Human reviewer is named
[FAIL] 2. Reviewer is a different person than the owner
[PASS] 3. Allowed repositories are listed (owner/name, no wildcards)
[PASS] 3. Allowed environments are listed
[PASS] 3. Production and secrets are explicitly forbidden
[PASS] 4. At least 3 acceptance criteria
[PASS] 4. Explicit non-goals are listed
[PASS] 5. Permission bounds are defined for every agent
[PASS] 5. No agent may merge (merge is human-only)
[PASS] 5. No agent may write to any branch (least privilege)
[PASS] 5. A review agent exists and is read-only

RESULT: INVALID - 2 problem(s):
  - REVIEWER: humanReviewer must be a named human (not an agent, not empty)
  - SEPARATION: owner and reviewer must be different people (never merge your own work)
exit code: 1
```

The real inputs file is **INVALID on purpose**: the human reviewer is blank, and the tool refuses to start the AI-COO until a real person is named.



Demo screenshot: the real validator in the browser. An agent allowed to merge and a review agent allowed to write are both rejected

A bug the tests found in my validator: with no agents defined, the 'review agents are read-only' check passed *vacuously* (an empty object failed 13 checks, not 14). I fixed the validator to require that a review agent exists (independent review is mandatory) and added a regression test; no assertion was weakened. 23 tests pass.

7. Day 17 - AI-COO Task Lifecycle

Lab: take a vague request ('Add dark mode') and use an LLM acting as AI-COO to split it into scoped tasks. The cards are validated by code (explicit files, non-goals, 2+ acceptance checks, dependencies, **no two parallel cards sharing a file**, exactly one human merge gate after an independent review). I also implemented the handbook's lifecycle as a state machine where the human gates are enforced.

Card	Title	Assignee	After
T1	Define light and dark colour tokens as CSS variables	task-agent	-
T2	Theme state hook: saved choice, else OS preference	task-agent	-
T3	Accessible theme toggle and mount it in the app header	task-agent	T2
T4	Move existing styles onto the colour tokens	task-agent	T1
T5	Automated WCAG AA contrast test for both themes	task-agent	T1, T4
T6	Browser flow: toggle, persist across reload, keyboard only	task-agent	T3, T4
T7	Independent review of the whole diff	review-agent	T1, T2, T3, T4, T5, T6
T8	Human merge approval (security and scope verification)	human	T7

Dependency waves: T1,T2 | T3,T4 | T5,T6 | T7 | T8. The target is the Day 19 capstone. The feature itself is **not built**: the lab is about decomposition.

Rules enforced by the state machine

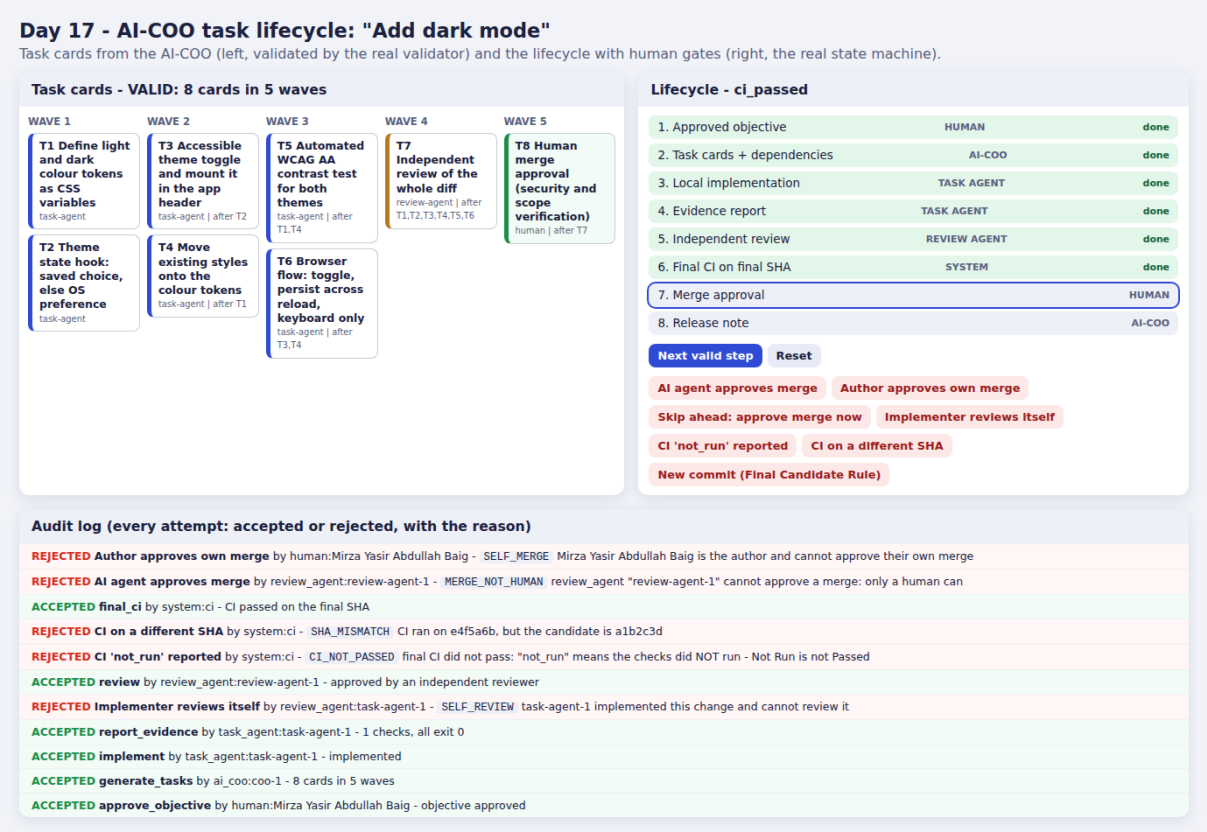
• Only the named human approves the objective and the merge; **an AI agent can never approve a merge**, and **the author cannot approve their own**.

• Steps cannot be skipped or reordered; the wrong kind of actor is refused; the implementing agent cannot review its own work.

• Evidence must list the exact commands, all with exit 0; review, evidence and CI must all be for the **same SHA**.

• CI 'not_run' or 'infra_blocked' is **Not Run, not Passed**.

• **Final Candidate Rule:** a new commit wipes evidence, review and CI; after merge approval the code is frozen. A run cannot start unless the Day 16 inputs are valid.



Demo screenshot: the audit log shows rejected illegal moves (self-merge, AI agent merge, CI not run, wrong SHA, self-review) with the reason for each

49 tests pass (21 task-card + 28 lifecycle). The lifecycle models the pipeline only; identity is a string here and would come from authenticated accounts in a real system. The AI-COO in this lab was Claude using the Day 16 brief; the validator checks structure, not whether the scope is right.

8. Day 18 - Working Safely with Agents

Lab: write a safe handoff report containing *only* a PR link, the final SHA, the scoped objective, test evidence and remaining blockers (no raw code, no secrets). I built a secret scanner (10 rules, redacted output), a repository safety audit, a pre-commit hook that scans staged content, and a handoff generator that **verifies an exact commit in a clean git worktree** and refuses to write a report that fails its own validator.

Repository safety audit (real run: npm run safety)

```
[PASS  ] No secrets in tracked files
         153 files scanned, 0 findings (11 fake/placeholder values suppressed)
[PASS  ] .gitignore blocks .env, key files and node_modules
         all required patterns present
[PASS  ] No .env files are tracked
         none tracked
[PASS  ] CODEOWNERS file exists (review ownership)
         found
[PASS  ] Pull request template exists (Week 2 format)
         found
[PASS  ] Git history is an attributable audit trail
         53 commits, 0 without author name/email
[PASS  ] Local pre-commit secret scan is installed
         hook installed
[PASS  ] No production credentials in the agent environment
         no sensitive-looking environment variable names (names only were checked; values are never read)
[MANUAL] Branch protection on main (PR required, 1+ approval, status check, no force-push)
         GitHub setting - cannot be verified from a local clone. Owner must enable it: see REPO_SAFETY.md
[MANUAL] GitHub secret scanning and push protection enabled
         GitHub setting - cannot be verified locally. Owner must enable it: see REPO_SAFETY.md
[MANUAL] Agent tokens are least-privilege (fine-grained, this repo only, no admin, no merge)
         Depends on how the agent is connected - verify in GitHub token settings
[MANUAL] GitHub audit log is reviewed
         Needs an organisation or account audit log; git history above is only the local proxy

SUMMARY: 8 pass, 0 fail, 0 warn, 4 manual (not verifiable locally)
```

The handoff report (the lab deliverable, as generated)

```
# Handoff report

## PR link

NOT OPENED

## Final SHA

44b9f57

## Scoped objective

Deliver Days 11-18 (task agent, review agent, token diet, tests that matter, security and privacy, AI-COO
    inputs and lifecycle, repository safety) as locally tested work on main. Nothing is deployed.

## Test evidence

- npm run verify (on 44b9f57) -> exit 0 (Prettier clean, TypeScript clean, 17 suites, 211 tests passed)
- npm run safety (on 44b9f57) -> 0 failing checks, 7 pass; secret scan: 153 files scanned, 0 findings (11
    fake/placeholder values suppressed); 4 GitHub settings not verifiable locally

## Remaining blockers

- Hosted CI has not been run on this SHA.
- No human reviewer is named yet (day-16-ai-coo/inputs/coo_inputs.json has humanReviewer set to null).
- Branch protection and GitHub secret scanning cannot be verified from a local clone; the owner must enable
    them.
- Playwright browser checks were run per day and were not re-run on this SHA.
- npm audit reports 19 moderate advisories in dev-only test tooling (0 in runtime); the suggested fix is a
    breaking downgrade, so it was not applied.
```



Demo screenshot: an unsafe handoff (extra section, fenced code, a token) is rejected with reasons; the secret value is never shown

What the audit and tests actually found

• **Missing controls:** no CODEOWNERS and `.gitignore` did not ignore `.env` or key files. Both added.

• **A scanner false positive** in my own Day 15 test (a fake password). I did not weaken the rule: I added an explicit, reviewable inline `secret-scan:allow` marker.

• **The demo page tripped the scanner** because adjacent string fragments looked like a URL with credentials; I changed how they are split and re-scanned: 0 findings.

• **A fixture bug of mine:** the 'tracked .env' test never tracked the file because the fixture's own .gitignore ignored it. The check was right; the fixture was fixed.

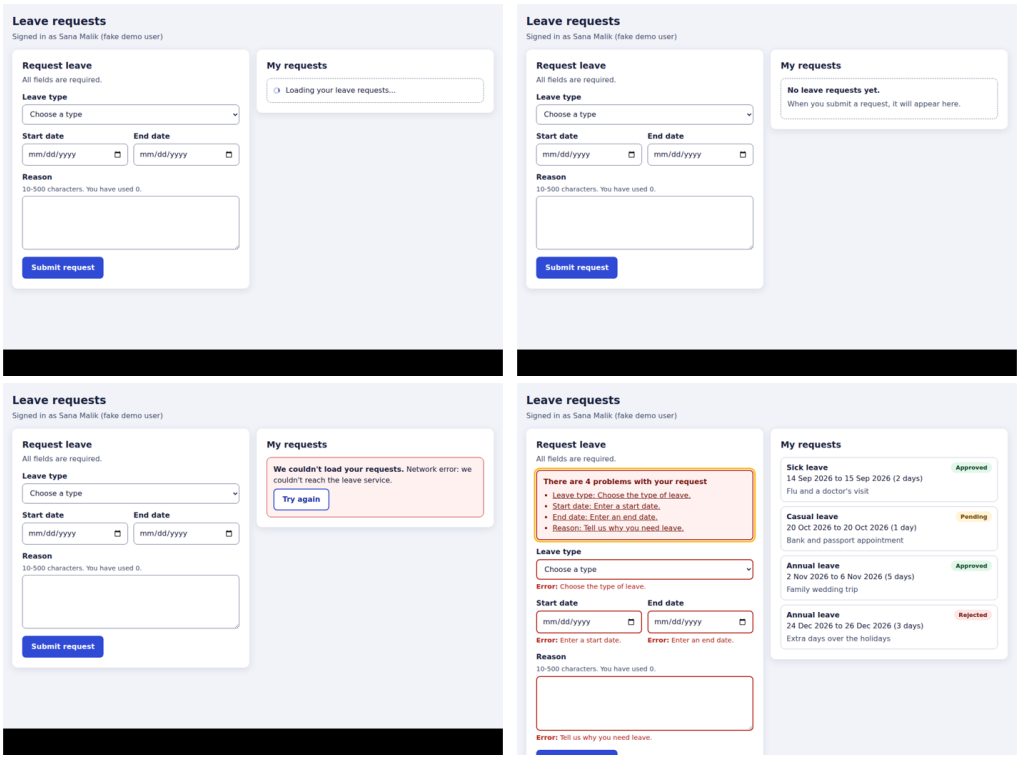
• **MANUAL items** (branch protection, GitHub secret scanning, token scopes, audit log) are reported as not verified, with exact owner steps in REPO_SAFETY.md. The PR link is 'NOT OPENED' and listed as a blocker.

44 tests pass (scanner 15, handoff 20, repo safety 9). A pattern scanner is a safety net, not proof of absence; GitHub push protection is the stronger control.

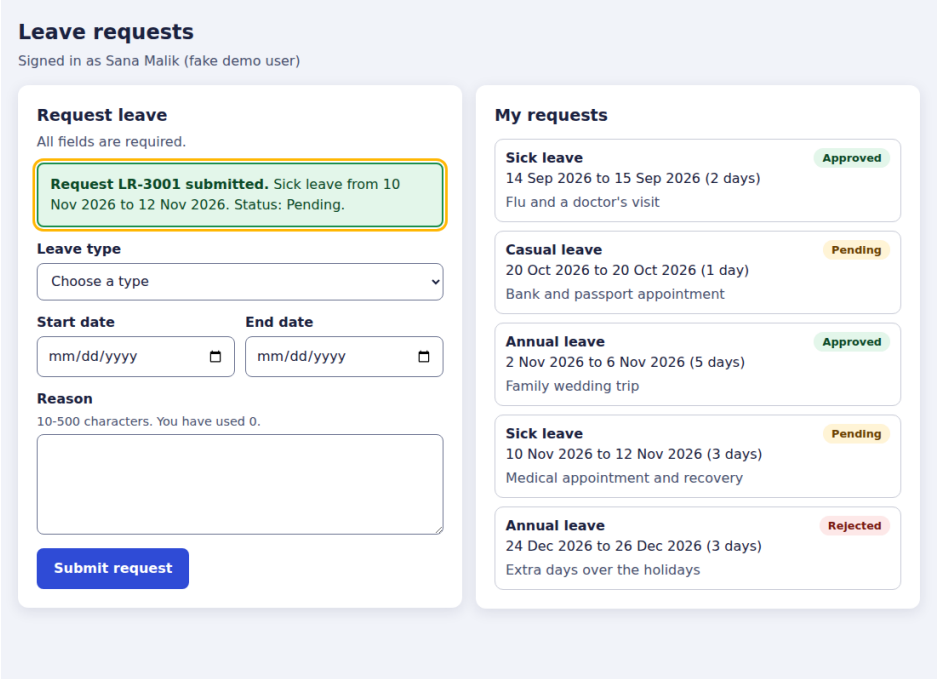
9. Day 19 - Capstone: Responsive Leave Request Form

The synthesis of all four weeks: built from the Day 13 brief, plan first, six focused commits, with typed fake data, validation, all four UI states, full keyboard support, **one focused component test** and **one browser flow test**.

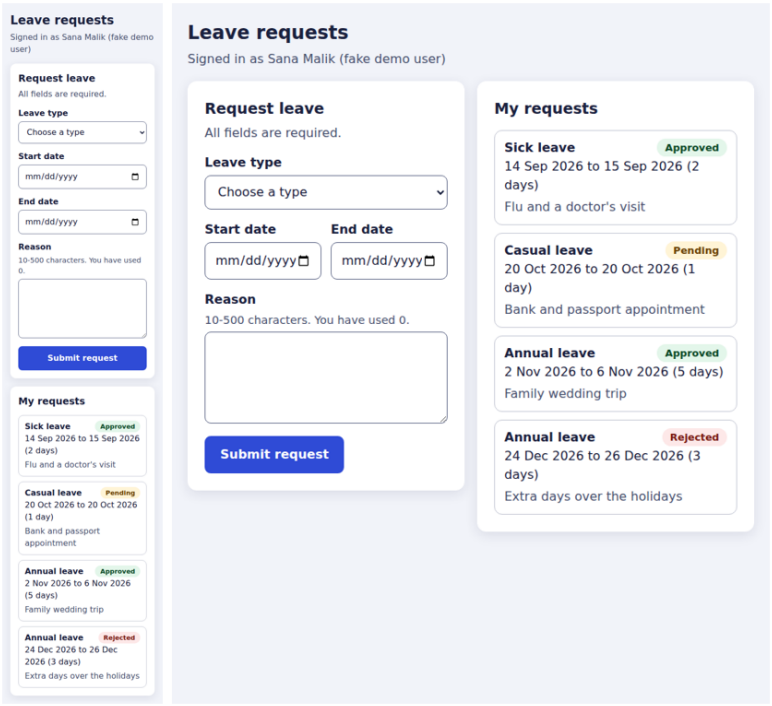
Requirement	How it is met / evidence
Responsive	1 column at 320px, 2 date columns from 390px, form + list from 768px; no overflow at 320/390/768/1280; all controls at least 44px tall
Typed fake data	types.ts and a fake API with FAKE people only; the fake server returns only the signed-in employee's requests
Input validation	Pure function: required, real dates (leap years), no past start, end >= start, max 30 days, reason 10-500 characters, no overlap with own approved leave. The fake SERVER re-validates
Loading / Error / Empty / Success	Loading spinner; error with Try again; friendly empty state; list plus confirmation banner
Keyboard + a11y	Native controls, logical tab order, visible focus ring, error summary with links, focus moved to the summary and to the confirmation
One component test	LeaveRequestForm.test.tsx: announced errors + focus, then correction, submission, confirmation, listing
One browser flow test	browser_flow.py: keyboard only, 6 steps, real typing into date fields
Clean history + Draft PR	6 Conventional Commits (DAY19_PLAN.md); DRAFT_PR.md in the Week 2 template (PR itself not opened)



Demo screenshots: loading, empty, load error (with Try again) and announced validation errors (summary has the visible focus ring)



Demo screenshot: after the keyboard-only journey, the confirmation banner has focus and the new request is listed as Pending



Demo screenshots at 320px (left) and 768px (right)

Real evidence

```
step 1 PASS: tab order = Leave type -> Start date -> End date -> Reason -> Submit request
step 2 PASS: empty submit -> 4 problems announced, focus on the summary
step 3-4 PASS: typed every field, Enter submitted, banner focused, request listed as Pending, form cleared
step 5 PASS: overlapping approved leave is refused with the clashing dates named
step 6 PASS: no horizontal overflow at 320px
width  320px: horizontal overflow 0px, layout columns 1, controls under 44px tall: 0 -> PASS
width  390px: horizontal overflow 0px, layout columns 1, controls under 44px tall: 0 -> PASS
width  768px: horizontal overflow 0px, layout columns 2, controls under 44px tall: 0 -> PASS
width 1280px: horizontal overflow 0px, layout columns 2, controls under 44px tall: 0 -> PASS
[loading] axe rules passed: 34, violations: 0
[loaded_list] axe rules passed: 31, violations: 0
[empty] axe rules passed: 29, violations: 0
```

```
[load_error] axe rules passed: 33, violations: 0
[validation_errors] axe rules passed: 37, violations: 0
[submit_success] axe rules passed: 35, violations: 0
[submit_error] axe rules passed: 36, violations: 0
[negative control] deliberately broken page -> 5 violations detected: button-name, color-contrast,
    image-alt, label, page-has-heading-one -> harness OK

TOTAL violations across 7 states: 0
```

Do the tests have teeth? (planted-bug checks)

Validation tests: 5 planted boundary bugs, 5 caught. Component test: 4 planted bugs, 4 caught. Browser flow: 3 planted bugs, 3 caught (output below). A negative control proves the accessibility audit reports 5 violations on a deliberately broken page, so it is not blind.

```
mutant [error summary never takes focus]: CAUGHT  -> FLOW FAILED: summary did not take focus
mutant [form not cleared after success]: CAUGHT  -> FLOW FAILED: Locator expected to be visible
mutant [new request not added to My requests]: CAUGHT  -> FLOW FAILED: Locator expected to be visible
```

Two bugs found after the capstone was merged (by review, not by the 42 tests or axe)

• **Stale server-side error:** an overlap error depends on both dates, but was cleared only when the field it was attached to changed. Fixing the End date left an error, a summary and `aria-invalid="true"` on a valid form. Failing regression test first (*Expected length 0, received 2*), then `setServerErrors({})` on any edit.

• **Focus lost after Try again:** that button disappears, so focus fell to <body> (WCAG 2.4.3). Reproduced in a real browser, failing test first, then focus moves to the stable 'My requests' heading. axe-core cannot see this because it inspects a state, not a transition.

• Per the Final Candidate Rule, everything was re-run on the new commit `76f4683` in a clean worktree: 21 suites, 255 tests at that point.

• **Three AI mistakes in test tooling** (a harness that printed 'MISSED' for a mutation it never applied, a wrong Tab assumption, a flawed first audit draft) are in day-19.../MISTAKES.md.

Honest limits: the Draft PR is not opened and hosted CI did not run; automated accessibility checks are partial and no manual screen-reader test was done; keyboard flow and screenshots are Chromium only; all data is fake and in memory; the demo pins 'today' to 2026-10-12.

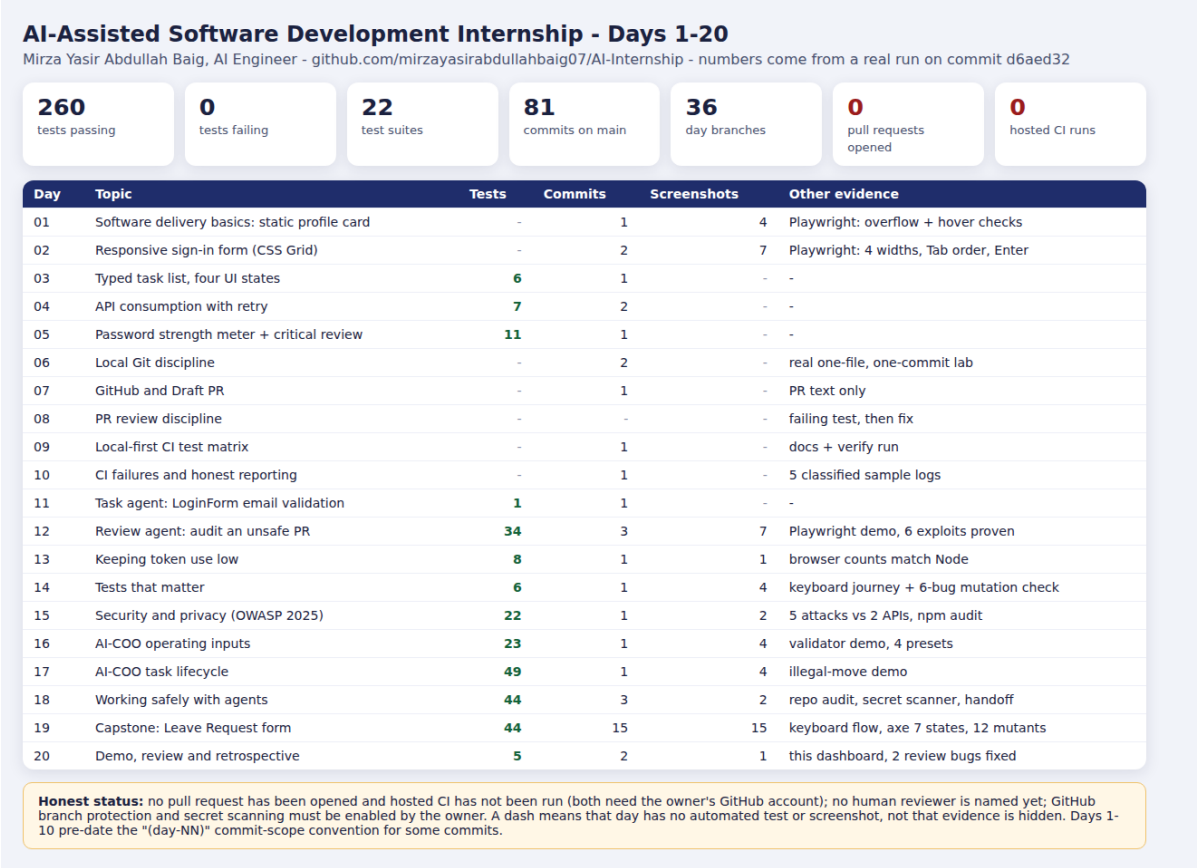
10. Day 20 - Demo, Review and Retrospective

The handbook asks for four things: demonstrate, explain, identify one AI mistake, and review a peer's PR.

Step	Deliverable
Demonstrate	DEMO_SCRIPT.md (5 minutes), tools/demo_run.js, and the dashboard built from real data
Explain	EXPLAIN_PROMPTS_AND_TOKENS.md (prompt chain, measured token choices) and STUDY_GUIDE.md
Identify a mistake	MISTAKE_CAUGHT.md: the stale server-side error that 42 tests missed
Review a PR	PEER_REVIEW.md: a practice review of the capstone with the Week 2 criteria (no peer PR was available)

Demo run (real, one command)

```
Demo run on commit d089e84
PASS   16.8s  Prettier, TypeScript and every test  [260]
PASS    0.2s  Safety audit (secrets, ignores, CODEOWNERS)  [8 pass, 0 fail, 0 warn, 4 manual (not verifiable
    locally)]
PASS    0.2s  Build the capstone demo bundle
PASS    1.7s  Keyboard-only browser flow (the ONE flow test)
PASS    6.3s  axe-core on 7 UI states (+ negative control)  [0]
PASS    2.2s  Responsive check 320/390/768/1280px
RESULT: all steps passed
```



AI-Assisted Software Development Internship - Days 1-20

Mirza Yasir Abdullah Baig, AI Engineer - github.com/mirzayasirabdullahbaig07/AI-Internship - numbers come from a real run on commit d6aed32

260	0	22	81	36	0	0
tests passing	tests failing	test suites	commits on main	day branches	pull requests opened	hosted CI runs

Day	Topic	Tests	Commits	Screenshots	Other evidence
01	Software delivery basics: static profile card	-	1	4	Playwright: overflow + hover checks
02	Responsive sign-in form (CSS Grid)	-	2	7	Playwright: 4 widths, Tab order, Enter
03	Typed task list, four UI states	6	1	-	-
04	API consumption with retry	7	2	-	-
05	Password strength meter + critical review	11	1	-	-
06	Local Git discipline	-	2	-	real one-file, one-commit lab
07	GitHub and Draft PR	-	1	-	PR text only
08	PR review discipline	-	-	-	failing test, then fix
09	Local-first CI test matrix	-	1	-	docs + verify run
10	CI failures and honest reporting	-	1	-	5 classified sample logs
11	Task agent: LoginForm email validation	1	1	-	-
12	Review agent: audit an unsafe PR	34	3	7	Playwright demo, 6 exploits proven
13	Keeping token use low	8	1	1	browser counts match Node
14	Tests that matter	6	1	4	keyboard journey + 6-bug mutation check
15	Security and privacy (OWASP 2025)	22	1	2	5 attacks vs 2 APIs, npm audit
16	AI-COO operating inputs	23	1	4	validator demo, 4 presets
17	AI-COO task lifecycle	49	1	4	illegal-move demo
18	Working safely with agents	44	3	2	repo audit, secret scanner, handoff
19	Capstone: Leave Request form	44	15	15	keyboard flow, axe 7 states, 12 mutants
20	Demo, review and retrospective	5	2	1	this dashboard, 2 review bugs fixed

Honest status: no pull request has been opened and hosted CI has not been run (both need the owner's GitHub account); no human reviewer is named yet; GitHub branch protection and secret scanning must be enabled by the owner. A dash means that day has no automated test or screenshot, not that evidence is hidden. Days 1-10 pre-date the "(day-NN)" commit-scope convention for some commits.

Dashboard screenshot: all 20 days, built from a real Jest run, git history and the file tree; the two red zeros are honest status

Review findings (Day 12 format)

#	Risk	Finding	Status
F1	Med	Stale server-side error left on a valid form after fixing the other date	FIXED 027b17b (failing test first)
F2	Med	Focus lost to the page body after Try again (WCAG 2.4.3)	FIXED 76f4683 (failing test first)

#	Risk	Finding	Status
F3	Low	Double-submit and failed-submit paths have no automated test (a real-browser probe confirmed: a triple click created 1 request; data kept after a failure)	OPEN
F4	Low	No upper bound on dates: a request for year 9999 is accepted (reproduced)	OPEN
F5	Low	The form imports CURRENT_EMPLOYEE from the fake API module; a real backend must derive identity from the session	OPEN (design note)
F6	Info	React renders the reason as text: submitting an HTML/onerror payload ran no script (probed)	OK

11. Retrospective: a green (or red) result can lie

Everything that went wrong across the internship, taken from the repository's own logs (15 items):

#	Day	What looked fine / happened	What was actually true	Kind
1	5	Password meter rated `P@ssw0rd` and `Abcdefg1` "Good"	Both are in every cracking dictionary	Limitation (documented)
2	8	Retry wrapper looked correct	Invalid JSON on a 200 was retried pointlessly	Product bug
3	12	A "no token" test failed	A default parameter silently replaced `undefined` with a real token: the test was wrong	Tooling misled
4	13	Noise-word list worked	Substring `tea` would also match "team"	Pre-empted
5	14	Browser journey "caught" a bug	It failed for the wrong reason (a glob did not match `?query`)	Tooling misled
6	15	Secure API looked right	`req.destroy()` dropped the connection instead of sending 413	Product bug
7	16	Validator passed an empty input on one check	"Review agents read-only" passed vacuously with no review agent	Product bug
8	18	Scanner flagged the Day 15 tests	A fake value; fixed with an explicit, reviewable allow marker	Limitation / noise
9	18	"Tracked .env" test	Never tracked the file: the fixture's own `.gitignore` ignored it	Tooling misled
10	19	42 tests + axe green	Stale server error left on a valid form	Product bug
11	19	Keyboard flow green	Focus fell to `` after "Try again"	Product bug
12	19	Mutation table said "MISSED"	The mutation was never applied (Prettier had reformatted the target)	Tooling misled
13	19	Keyboard flow failed	My test assumed one Tab per date field; Chromium has a calendar-button stop	Tooling misled
14	19	First audit draft	Waited for the result before doing the action	Pre-empted
15	20	Dashboard built and committed	The two generated files were unformatted, so `npm run verify` went red	Tooling bug

Totals: 5 product bugs; 6 tooling problems (5 where the checking tool itself gave a misleading result, plus 1 generated-file bug that turned `verify` red and was caught by the final run); 2 pre-empted before they bit; 2 limitations. Roughly 40% of the problems were in the tests, harnesses and generators an AI wrote, not in the product.

Rubric self-assessment (evidence, not a grade)

Area (weight)	Evidence	Why
Problem understanding and planning (20%)	Strong	150-word brief with 13 checked criteria, plan first, written non-goals
Code quality and scope discipline (20%)	Strong	Typed data, semantic HTML, new folders only; but two bugs shipped until review
Testing and honest evidence (20%)	Strong	260 tests, negative controls, planted-bug checks, 'Not Run' never reported as passed
GitHub / PR workflow (15%)	Partial	Clean history and templates, but no PR opened and no peer review
Security, privacy, accessibility (15%)	Strong, with caveats	OWASP 2025 lab, axe 0 violations, keyboard flow; no manual screen-reader test
Communication and teamwork (10%)	Partial	Per-day READMEs and logs; no teammate feedback given or received

Owner action checklist (cannot be done from here)

• Push `main` and the day branches; open the Day 7 and Day 19 **Draft PRs** from DRAFT_PR.md

- Name a **real human reviewer** in day-16-ai-coo/inputs/coo_inputs.json
- Enable **branch protection** and **secret scanning with push protection** (day-18-working-safely/REPO_SAFETY.md)
- Run hosted CI once on the final SHA
- Get a **peer review** on the capstone PR and triage findings F3-F5
- Try the capstone with a screen reader
- Prepare to explain your own code without notes (STUDY_GUIDE.md)

12. Final verification and Git history

Command: `npm run verify` (Prettier check, tsc --noEmit, Jest for the whole repository) on commit `851ffc9`: exit 0, **22 suites, 260 tests passed, 0 failed**. `npm run safety`: 8 pass, 0 fail, 4 manual; 204 files scanned, 0 secret findings. Commits after this one add documentation, the report and evidence only; no source file changed.

Most recent commits (text)

```
c199407 Merge docs/day-20-retro-item-15
778b541 docs(day-20): add the generated-file formatting bug as retrospective item 15
851ffc9 Merge fix/day-20-format-generated
528979d fix(day-20): format generated dashboard files inside the builder
d6aed32 Merge docs/root-readme-days-11-20
1dc7f4c Merge feat/day-20-demo-retrospective
8cb16b5 docs: index Days 13-20 and the reports folder in the root README
a1e989a docs(day-20): add dashboard built from real data and the demo-run evidence
d089e84 feat(day-20): demo script, practice review, mistake caught, retrospective, study guide and dashboard
    code
b18d92a Merge fix/day-19-retry-focus
b921617 docs(day-19): record the focus-after-retry bug, final SHA 76f4683 and re-run evidence
76f4683 fix(day-19): move focus to the My requests heading after Try again
ed524ff test(day-19): add failing regression test for focus lost after Try again
dbaa1f7 Merge docs/day-19-count-fix
05c84bc docs(day-19): correct the earlier test count in the mistakes log (42, not 49)
7e697c1 Merge fix/day-19-stale-server-error
0c697d8 docs(day-19): record the stale-error bug, new final SHA 027b17b and re-run evidence
027b17b fix(day-19): clear all server-side errors on any edit
4770ef7 test(day-19): add failing regression test for a stale server-side overlap error
eb6eed9 Merge feat/day-19-capstone-leave-request
1629f03 docs(day-19): add plan, mistakes log, Draft PR text and README for the capstone
92ca4dd test(day-19): add all-states axe-core audit (with negative control) and responsive check
```

To push (run on your machine inside the unzipped repo)

```
git remote add origin https://github.com/mirzayasirabdullahbaig07/AI-Internship.git
git push -u origin main
git push origin --all
# then open the Draft PRs, name a reviewer, enable branch protection
```

Workflow note: I merged the per-day branches locally so `main` holds everything. In a team repo with branch protection you would push each branch and have a human review the PR; never self-merge (Rule 4).

Mirza Yasir Abdullah Baig
AI Engineer | github.com/mirzayasirabdullahbaig07